

ISO 27001 Internal Audit Case Study Report

ISO 27001 Internal Audit Case Study Report

Introduction

Audit conducted using ISO 27001 clauses 5.2, 6.1, 9.2 with checklist and risk validation.

Enhancement

Risk findings linked with audit observations for better ISMS evaluation.

Conclusion

Improved ISMS maturity through audit and risk integration.

This report presents a simulated internal audit analysis of an Information Security Management System (ISMS) aligned with ISO/IEC 27001.

Audit was conducted using a structured checklist aligned with ISO 27001 clauses 5.2, 6.1, and 9.2.

The objective of the audit is to:

- Evaluate ISMS effectiveness
- Identify nonconformities
- Analyze root causes
- Recommend corrective actions

The audit approach is based on principles from ISO 19011.

2. Audit Overview

- **Audit Type:** Internal Audit
- **Organization:** XYZ Manufacturing Ltd (Simulated)
- **Scope:**

- Clause 5.2 – ISMS Policy
- Clause 6.1 – Risk Management
- Clause 9.2 – Internal Audit

Case Study 1 – Clause 5.2 (ISMS Policy)

Findings

Nonconformity 1 (Major)

Finding:

No documented ISMS policy available during audit review.

Evidence:

- No formal policy document provided
- No version-controlled policy records

Requirement:

Clause 5.2 requires a documented information security policy.

Nonconformity 2 (Major)

Finding:

ISMS policy does not include commitment to legal, regulatory, and contractual requirements.

Evidence:

- Policy draft lacks compliance statements

Nonconformity 3 (Minor)

Finding:

No evidence of continual improvement commitment in ISMS policy.

Nonconformity 4 (Minor)**Finding:**

ISMS policy has not been reviewed in over 3 years.

Evidence:

- No review logs or approval records

Nonconformity 5 (Minor)**Finding:**

Lack of awareness of ISMS policy among employees.

Evidence:

- No training records
- No communication emails

Root Causes

- Lack of top management involvement
- Absence of document control process
- No awareness or training program

Corrective Actions

- Develop and approve formal ISMS policy

- Include compliance and continual improvement commitments
- Establish document review cycle
- Conduct organization-wide awareness training

Case Study 2 – Clause 6.1 (Risk Management)

Findings

Nonconformity 1 (Major)

Finding:

No formal risk assessment and treatment methodology defined.

Evidence:

- No documented risk assessment procedure
- No defined risk criteria

Requirement:

Clause 6.1 requires a structured risk assessment process.

Nonconformity 2 (Major)

Finding:

The risk register is outdated and incomplete.

Evidence:

- No updates in last 12 months
- Missing risks (remote access, third-party risks)

Nonconformity 3 (Minor)

Finding:

No periodic review of risks and opportunities.

Root Causes

- Lack of defined risk ownership
- No standardized methodology
- Weak ISMS governance

Corrective Actions

- Implement formal risk assessment framework
- Maintain updated risk register
- Develop Statement of Applicability
- Schedule periodic risk reviews

Case Study 3 – Clause 9.2 (Internal Audit)

Findings

Nonconformity 1 (Major)

Finding:

No risk-based internal audit program established.

Evidence:

- No audit schedule based on risk
- No audit planning documents

Nonconformity 2 (Major)

Finding:

Internal audits not conducted as per schedule.

Evidence:

- Missing audit reports
- No justification for delays

Nonconformity 3 (Minor)

Finding:

Lack of evidence-based audit reporting and follow-up.

Evidence:

- No supporting audit evidence
- No corrective action tracking

Root Causes

- Poor audit planning
- Lack of accountability
- No follow-up mechanism

Corrective Actions

- Establish risk-based audit program
- Ensure timely execution of audits
- Maintain audit evidence and documentation
- Implement corrective action tracking system

Conclusion

The audit identified several major and minor nonconformities impacting the effectiveness of the ISMS.

Key areas for improvement include:

- Policy governance
- Risk management processes
- Internal audit execution

Addressing these gaps will significantly improve ISMS maturity and support compliance with ISO/IEC 27001 requirements.